CS STUDY · NETWORK

# 주소창 자물쇠 뒤에서 벌어지는 일

## SSL/TLS 핸드셰이크

발표 · 최승우



# 그냥 HTTP는 '엽서'와 같다

내 데이터는 공유기, 통신사 장비 등 여러 곳을 거쳐 간다. 봉투 없이 보내면 거쳐 가는 누구나 다음 세 가지를 할 수 있다.

01

## 엿보기 · 도청

카페 와이파이에서 누군가 내 비밀번호를 그대로 읽는다

02

## 바꿔치기 · 변조

송금할 계좌번호가 중간에서 다른 번호로 바뀌어 도착한다

03

## 사칭 · 위장

진짜 은행처럼 보이는 가짜 서버에 접속해 버린다

# TLS가 지켜주는 세 가지

| 막아야 할 위험 | TLS가 주는 것 | 어떻게? |
|---|---|---|
| 엿보기 · 도청 | 기밀성 | 내용을 암호화해서 읽을 수 없게 |
| 바꿔치기 · 변조 | 무결성 | 메시지마다 위조 방지 도장을 찍어서 |
| 사칭 · 위장 | 인증 | 인증서와 디지털 서명으로 신원 확인 |

핸드셰이크는 이 세 가지를 위한 '준비 절차'다.

# TLS는 TCP 위, HTTP 아래에 있다




## HTTP + TLS = HTTPS

1. TCP 3-way handshake로 연결
2. **TLS 핸드셰이크로 열쇠 맞추기**
3. 암호화된 HTTP 주고받기

HTTP 입장에선 평소처럼 말할 뿐, 포장은 TLS가 대신 해준다.

# 암호의 두 가지 도구: 대칭키와 비대칭키

| | 대칭키 | 비대칭키 (공개키 암호) |
|---|---|---|
| 방식 | 열쇠 하나로 잠그고, 같은 열쇠로 연다 | 열린 자물쇠(공개키)는 나눠주고, 여는 열쇠(개인키)는 나만 갖는다 |
| 장점 | 빠르다 | 열쇠를 건넬 필요가 없다 · 서명도 된다 |
| 단점 | 처음에 그 열쇠를 어떻게 건네지? | 느리다 |

핵심 아이디어

# 느리지만 안전한 방법으로 열쇠만 정하고, 빠른 대칭키로 실제 대화를 한다

이 ‘열쇠를 정하는 과정’이 바로 TLS 핸드셰이크다.

# 인증서는 서버의 '신분증'이다

| 신분증 | 인증서 |
| --- | --- |
| 이름 | 도메인 (naver.com) |
| 사진 | 서버의 공개키 |
| 발급 기관의 직인 | CA(인증기관)의 서명 |
| 유효기간 | 유효기간 |

## 믿음의 사슬

**루트 CA**
OS·브라우저에 미리 내장

↓

**중간 CA**
루트가 서명해 줌

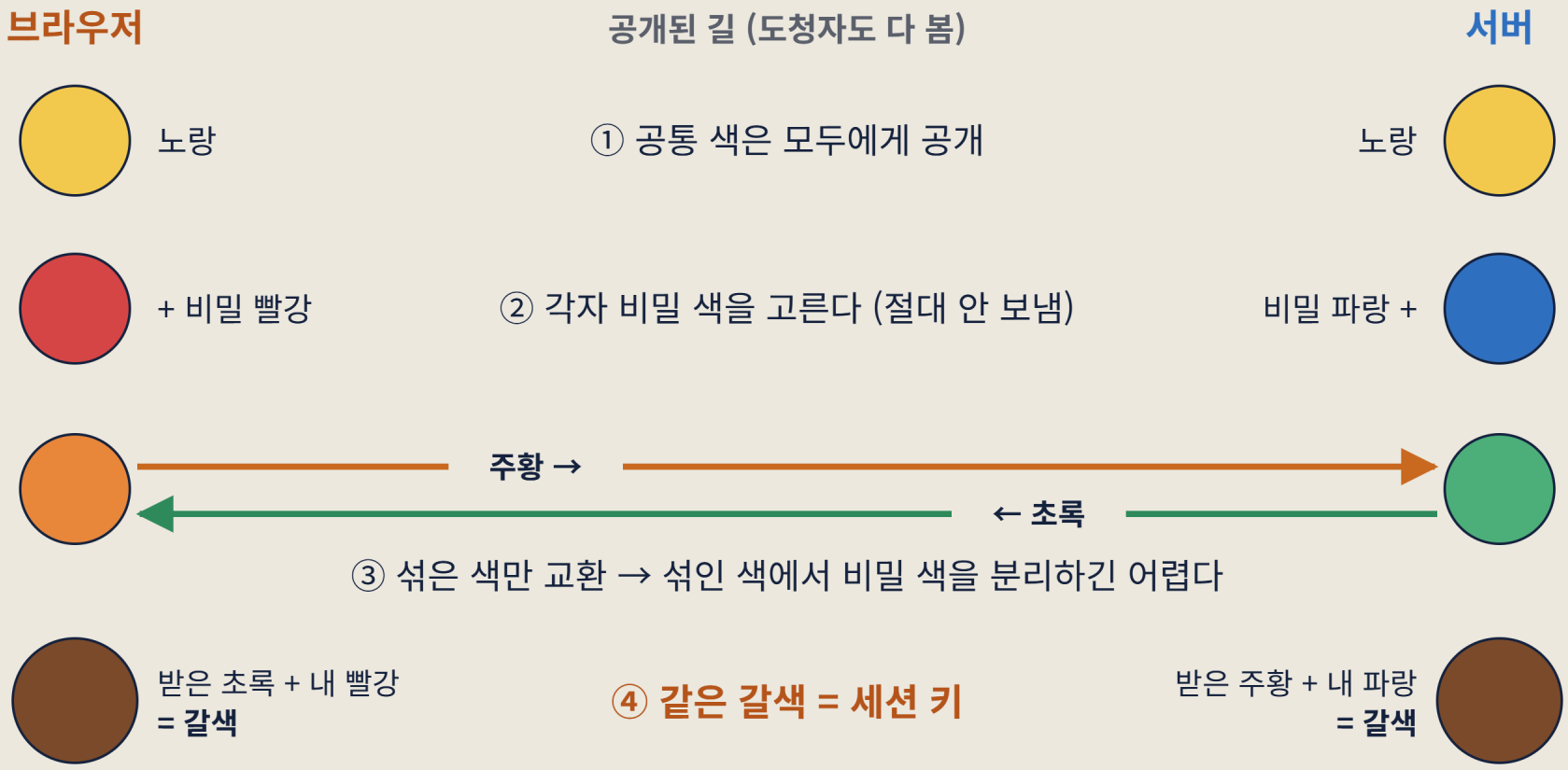
↓

**naver.com**
중간 CA가 서명해 줌

# 전체 흐름: 왕복 한 번이면 끝난다



# 열쇠를 보내지 않고 맞추는 법: 물감 섞기



05 · 정리

# 한 장 요약과 퀴즈

1. HTTP는 엽서 → 도청·변조·사칭 위험
2. 물감 섞기로 세션 키를 보내지 않고 맞춘다
3. 인증서 + 서명으로 진짜 서버인지 확인
4. 이후 대화는 빠른 대칭키로 암호화

**Q1.** 왜 처음부터 끝까지 비대칭키로 암호화하지 않을까?

**Q2.** 세션 키는 네트워크로 전송될까?

**Q3.** 인증서 확인을 건너뛰면 어떤 공격이 가능할까?